Maryville University

CTI Analysis Project | Final Report

Reece Bevan

ISYS 485: Incident Response and Threat Intelligence

November 2nd, 2025

DISCLAIMER:

This document is a fictional, academic exercise for educational purposes only. All scenarios, targets, and findings are entirely hypothetical. No real sensitive data has been verified or exploited. Any resemblance to real individuals or active security postures is coincidental.

Executive Summary

Advanced Persistent Threat 29 (APT29) is a known threat group that is primarily connected to Russia. They often target government networks from NATO member countries with the goal being to steal credentials, system information, and internal organizational data by espionage. They are a highly funded threat group with high capabilities. They are stealthy, patient, and large. The biggest attack from APT29 is the SolarWinds supply-chain attack in 2020. APT29 gained access to an internal environment of SolarWinds and planted a backdoor called “SUNBURST” into a software update of a flagship network monitoring product that is used by the government called Orion. Upon installation of this update, APT29 gained access to government networks and stayed under the radar for weeks and affected agencies like Homeland Security, Department of Treasury, Department of Commerce, and many more.

In this fictional scenario, APT29 attacked a state government organization by using a spear-phishing campaign that posed as budget notices from a trusted state contact. The emails contained malicious HTML attachments using HTML smuggling to bypass security. Once opened, the code delivered an ISO file with a Windows LNK file that executed a BEATDROP malware variant, which is connected to APT29 C2 servers hosted on cloud services. In simpler terms, APT29 used spying software that was hidden on cloud services to stay under the radar. The key risk of this attack shows that APT29 is trying to steal government information, and with them being directly in the system, they can do whatever they want such as altering and disrupting operations in the network. APT29 can also use this attack to move across other state agencies that are connected to the network acting like a virus that is spreading across the country.

This report discusses findings on APT29 using several types of data collection tools such as Open-Source Intelligence (OSINT), MITRE ATT&CK Framework, and Indicators of Compromise (IoC). There will also be defense recommendations for the state government organization sorted by immediate, mid-term, and long-term plans.

Methodology

As previously mentioned, the data collection approach for APT29 uses OSINT, MITRE ATT&CK, and IoCs. Some OSINT websites that were utilized were Have I Been

Pawned (HIBP), Dehashed, IntelX, and LinkedIn. These sources worked together by finding out how much information is open to get on the internet and how it can be used against victims. MITRE ATT&CK was used more for the CTI aspect of finding Tactics, Techniques, and Procedures (TTPs). This was done to gain intel on the threat group and the ways they attack or move through networks. Finally, IoCs were implemented in the data collection by detecting IoCs, connecting them to MITRE, aligning them to this scenario, evasion methods, and recommendations for each IoC. These all work together to provide detailed data collection for this project.

With this project, there were limitations and challenges that were encountered. One of the biggest challenges was limited prior knowledge of concepts that were presented in this course. Prior knowledge only includes a cybersecurity principles course, which made self-learning a significant requirement to understand the material in depth. This took extra time and determination to learn the topics efficiently. Ultimately there were significant learning improvements that got better throughout the course of this project. Another challenge was limited access to real data. Although this project uses a realistic scenario, it is still fictitious. Students at a university do not have access to high intelligence data that would be available for those in government positions. This means there is a lot of speculation as inferences. With this limitation comes a paywall limitation as well. For sources such as Dehashed, to see in depth breach information, there is a paywall, which causes more speculation and inferences. Despite these challenges, there were still significant data collection and findings for this project.

Data Analysis and Findings

The first data collection type was OSINT capture. There is surprisingly a large amount of private information that is easily accessible to anyone on the internet. The analysis began by finding out how easy it is to locate a government email by a quick Google search and identified a generic government email address. Then this email was put into two different sources such as HIBP and Dehashed. Both websites revealed that there's personal information tied to this email that was in several breaches. The personal information in these breaches included dates of birth, genders, names, passwords, phone numbers, physical addresses, and IP addresses. Then with a simple search of a government domain in Dehashed revealed company emails of thousands of people across many different government areas. Although most don't reveal passwords, some still do. With a simple paywall, it can reveal passwords. This seems to be due to people in the government using their work emails on any website. These websites then get breached revealing all the personal information. APT29 could easily use this to gather passwords and brute force an attack, especially because many people reuse passwords for multiple accounts. One of the emails listed in Dehashed was easily found on LinkedIn by searching the name associated with the email. There is then information provided about previous jobs, education, connections, and activity in addition to password leaks from breaches. APT29 can use a combination of tools to piece together a person in a company. For example, they could now know a lot about this Ron person from just using a couple tools.

They can also piece together not just one person, but many people's information which is crucial to using efficient phishing emails or scams from impersonation.

The next step was to analyze APT29's TTPs and map them to the MITRE ATT&CK framework. This was to gain a better understanding of how this threat group functions. MITRE provides a detailed list of TTPs known to APT29, and the goal of mapping is finding these TTPs and understanding how they use this in their attacks. Below provides a table of the data collected.

APT29 TTP Mapping Chart

ATT&CK Tactic	Technique ID	Technique Name	How APT29 Uses This
Initial Access	T1195.002	Supply Chain Compromise: Compromise Software Supply Chain	APT29 tries to gain initial network access via a trojanized update in software
Execution	T1087.002	Account Discovery: Domain Account	They used PowerShell to discover accounts by executing malicious code
Collection	T1595	Active Scanning: Vulnerability Scanning	They often scan environments to identify vulnerabilities that they can use to exploit their systems
Impact	T1037.004	RC Scripts	Adversary has run commands on a system to execute malware on startup
Credential Access	T1110.003	Brute Force: Password Spraying	Adversary has successfully brute forced passwords many times
Credential Access	T1586.002	Compromise Accounts: Email Accounts	They have gathered data on email accounts to enable phishing campaigns to take control of dormant accounts
Exfiltration	T1005	Data from Local System	Adversary has stolen files from compromised networks
Lateral Movement	T1021.007	Remote Services: Cloud Services	They have moved laterally inside networks using RDP or SMB

Knowing the enemy is the biggest way to combat them. Using MITRE is a very effective way to go about this since they provide all the information needed to understand a threat group, especially a large threat group such as APT29.

Following TTP mapping, the third step was to trace the attack path of APT29, identify how this group moves through networks, and assess how the attacker bypassed security defenses. In other words, finding IoCs related to APT29 and the scenario. This can be done by using the previous TTPs and connecting them to IoC types (Email Sender, URL, File Name, etc.), aligning them to the scenario, and providing evasion methods used by the threat group. There is another table below that gathers this information together.

IoC Table

Attack Stage	Technique ID	Technique Name	IoC Types	Alignment to Scenario	Evasion Methods
Initial Access	T1566	Phishing	Email Sender, URL, File Name	APT29 is known to have phishing campaigns for U.S. government officials. The state government can easily be a target for APT29 and cause victims to download malware.	APT29 is highly funded on even the basic fronts such as phishing campaigns. They make them look real and have highly trained attackers produce good fake emails.
Collection	T1114	Email Collection	Email Sender	APT29 can gather information on different government emails to impersonate them which will further increase the chances of someone clicking on a phishing email.	APT29 is good at collecting data from breaches of emails, especially ones retaining to government officials.
Lateral Movement	T1021	Remote Access	IP Address, Process Name	APT29 can move to sensitive servers to gather more information by running executable files on services. In this case, it could be to gather government information such as emergency management coordination.	The adversary can move quickly through the system without being able to be detected, or when they are detected, it will be too late.

Initial Access	T1195	Supply Chain Compromise	File Name, File Hash, Registry Key	One of the biggest breaches done by APT29 was the SolarWinds Breach, where APT29 inserted malicious code in a pushed update from a supply chain. They can do a similar attack to compromise state government organizations.	Supply chains are third party from the organizations, so a lot of the time the organization will rely on their security and can't really control it. Supply chains connect to many organizations, so it is way easier for them to infect thousands of organizations by just infecting one.
Command and Control	T1071	Application Layer Protocol	Domain, IP Address, URL	After a system is compromised, in this case, a state government organization, APT29 will have to connect with their malware on the systems, and they do this by setting up a C2 channel to blend with internet traffic.	APT29 will disguise the channels using protocols such as HTTPS since they will blend with other internet traffic making it hard to see them.

This step of the process is like the second layer to TTP mapping. Identifying IoCs provides even more threat intelligence on APT29 and starts to complete a full picture whereas just TTP mapping provides more general information.

The final part of the data collection process was organizing a gap analysis using MITRE D3FEND. D3FEND is used for the defense side of cybersecurity, whereas ATT&CK is the offense side. D3FEND provides techniques that can be put in place for any company to help provide more security. In the final chart listed below, it outlines the mapping of TTPs to D3FEND, asking if this defense was already in place, and security gaps.

Gap Analysis				
ATT&CK Technique ID	ATT&CK Technique Name	Mapped D3FEND Technique	Control Present?	Security Gap
T1195.002	Supply Chain Compromise: Compromise Software Supply Chain	Software Update (harden)	Partially: A lot of government systems will use up to date software, but some will still use old software	Some systems may not support certain updates

T1087.002	Account Discovery: Domain Account	Domain Account Monitoring (detect)	Yes: Since government systems are higher up, it is likely they monitor changes to domain user accounts	The monitoring may not happen in real time so could be behind
T1595	Active Scanning: Vulnerability Scanning	N/A (Overall security will decrease number of vulnerabilities)	Partially: A lot of government systems do vulnerability scanning, but not often	May produce many false positives and negatives
T1037.004	RC Scripts	Decoy File (deceive)	Maybe: Decoy files may be used by the state government but also equally could not	Decoy files are just a possible fix, they can still figure out the decoy and exploit the real file
T1110.003	Brute Force: Password Spraying	Strong Password Policy (harden)	Yes: The state government should keep a policy on having strong unique passwords	Even though it is a policy, some people still may not follow it and end up getting successful attempts
T1005	Data from Local System	File Analysis (detect)	Yes: Anti-viruses often have file scanning in them and even Microsoft Defender can scan a file	Although anti-viruses can help, complex malware or threats can go undetected
T1021.007	Remote Services: Cloud Services	Network Traffic Signature Analysis (detect)	Maybe: Companies can get pretty access to different tools such as AlienVault or WireShark	Traffic can be highly encrypted which can make it difficult to decipher

This was the final step to gain intelligence on APT29. At this point, there is enough information to understand how the threat operates, attacks, and exploits defense strategies to complete their objective of intel. All the previous data collection processes work together and build off one another to accomplish this task.

Immediate and Long-Term Cyber Defense Strategies

After carefully considering the data, there are some immediate (next 48 hours), mid-term (next 30 days), and long-term (31 days+) action plans for the State Capitol to put into place to help prevent future attacks. First and foremost, immediately disconnect any workstations, accounts, or servers that are suspected to be compromised from the network. This is so APT29 can stop moving through the networks and cause more damage. The state government should also block all known IoCs listed in the data collection to block activity associated with APT29. Finally, for immediate action, store all forensic evidence related to the attack such as logs and memory dumps for further analysis. This is to bring together all the strongest evidence in the attack together to make it easier for future action strategies.

Mid-term recommendations start by auditing all services for any evidence of malware, unauthorized accounts, or any suspicious activity. This is to further gain intel on everything that was compromised and will help with further strategies even more. Next is to increase frequency of vulnerability scanning. Even if vulnerability scanning can have false negatives and positives, it is highly important to still frequently run scans. The frequency depends on the type of scan, but most types of scans should be every week or biweekly. There should also be highly strict policies on security policies such as passwords. There should be a requirement for Multi Factor Authentication (MFA), as well as improving password requirements. There should also be no way anyone can use their government email for regular use websites, as this is what causes breaches. Finally, delete dormant accounts that are not part of the government anymore. This is so old accounts can’t be compromised since those accounts are often easier to get into.

As far as long-term recommendations, put in place threat intelligence awareness. Using tools like MITRE can be an easy way to stay up to date on known threats, especially APT29. These threat groups are always changing and adapting, and it is important to adapt with them by gaining more intel on them constantly. There should also be red team and blue team scenarios to improve response on attacks. This can be done by simulating real current attacks and defending against them. This coincides with regularly conducting phishing tests on employees to further enhance intel. Supply chain security protocols should also be established. There should be a requirement for vendors to meet certain criteria and cybersecurity standards to prevent future supply chain attacks. The SolarWinds breach is a good example as to what could happen if these protocols weren't in place.

These actions will help prevent future attacks and mitigate the attack done from APT29. These should be taken seriously and even though it requires a lot of time and money to invest in, the potential damage could cause significantly more time and money. Although APT29 is highly capable and funded, these types of attacks can happen from anyone, anywhere, which is why it is important to continue these recommendations even if the attack from APT29 is mitigated.

Conclusion

This threat to state's government shows that anyone can be attacked at any time. APT29 will always try to target victims and just one vulnerability can cause a catastrophe

within the government. Without action to this threat, these attacks could happen again and could lead to major breaches in the U.S. government. It also damages confidence in the government. The U.S. has been seen as a strong country to other nations and cyberattacks loses public confidence in our ability to control and prevent threats. One of the most efficient ways to combat these attacks is cyber threat intelligence (CTI). CTI provides faster incident response times, better understanding of the threat world, and is effective in the long-term. It is essential to protect the future of the U.S. government and state governments at a cyber level to ensure a secure and trustworthy nation in the digital world.

Citations

APT29, IRON RITUAL, IRON HEMLOCK, NobleBaron, Dark Halo, NOBELIUM, UNC2452, YTTRIUM, The Dukes, Cozy Bear, CozyDuke, SolarStorm, Blue Kitsune, UNC3524, Midnight Blizzard, Group G0016 | MITRE ATT&CK®. (2015). Mitre.org. https://attack.mitre.org/groups/G0016/

MITRE D3FEND Knowledge Graph. (2025). Mitre.org. https://d3fend.mitre.org/

Have I Been Pwned: Check if your email address has been exposed in a data breach. (2025). Have I Been Pwned. https://haveibeenpwned.com/

DeHashed — #FreeThePassword. (2020). Dehashed.com. https://dehashed.com/

Intelligence X. (2025). Intelx.io. https://intelx.io/